

ROAD TO HALL OF FAME - ACTIVIDAD 08
**LAB: FILE PATH TRAVERSAL, TRAVERSAL
SEQUENCES BLOCKED WITH ABSOLUTE PATH
BYPASS**

Mtro. Servando López Contreras

Informe realizado por:

181583 Angel Aaron Acuña Quezada

Contenido

Datos del Laboratorio	3
Marco Teórico y Fundamentación Técnica	3
Procedimiento	4
Explicación del Payload	6
Mitigación Recomendada.....	7
Referencias	7

Datos del Laboratorio

- **Nombre del laboratorio:** File path traversal, traversal sequences blocked with absolute path bypass
- **Nivel:** Practitioner
- **Tipo de Explotación:** File Path Traversal
- **Objetivo del laboratorio:** Explorar la vulnerabilidad de File Path Traversal a través del método de petición "GET" del protocolo HTTP, con el fin de poder leer el archivo `/etc/passwd`.

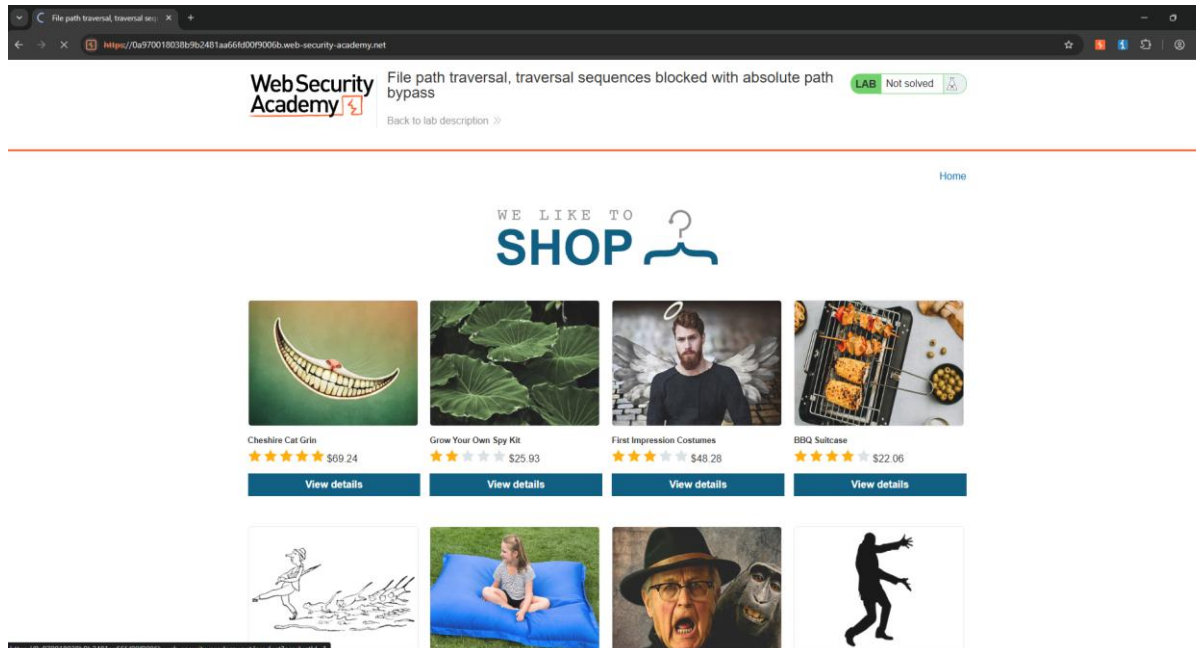
Marco Teórico y Fundamentación Técnica

Concepto: De acuerdo con OWASP, un ataque de *Path Traversal* (también conocido como *Directory Traversal*) tiene como objetivo acceder a archivos y directorios que están almacenados fuera de la carpeta raíz web. Al manipular las variables que hacen referencia a los archivos usando secuencias de "punto-punto-barra" (`../`) o rutas absolutas permite a un atacante acceder a archivos y directorios en el sistema de archivos, incluyendo código fuente de la aplicación, configuraciones y archivos críticos del sistema. En el caso particular de este laboratorio, la aplicación implementa un filtro que bloquea las secuencias relativas (`../`), pero omite validar si la ruta suministrada ya es absoluta, lo que constituye un bypass del control de seguridad implementado.

Impacto en la Triada CIA: Esta vulnerabilidad compromete de manera directa la "Confidencialidad" de la información, ya que expone datos sensibles del sistema operativo.

Perspectiva OWASP: Clasificada dentro de la categoría de *Broken Access Control* (Control de Acceso Roto), ocurre cuando la aplicación utiliza la entrada del usuario para construir una ruta de archivo sin validar o sanear adecuadamente dicha entrada, permitiendo escapar de la estructura de directorios autorizada.

Procedimiento



Se ingresó a la tienda virtual del laboratorio, en la cual podemos ver que carga varias imágenes de productos.

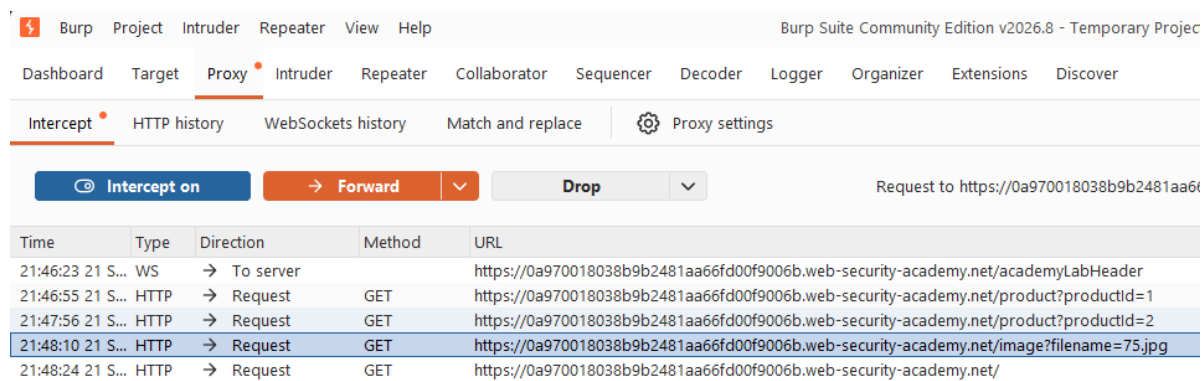
1. Live passive crawl from Proxy (all traffic)

Summary

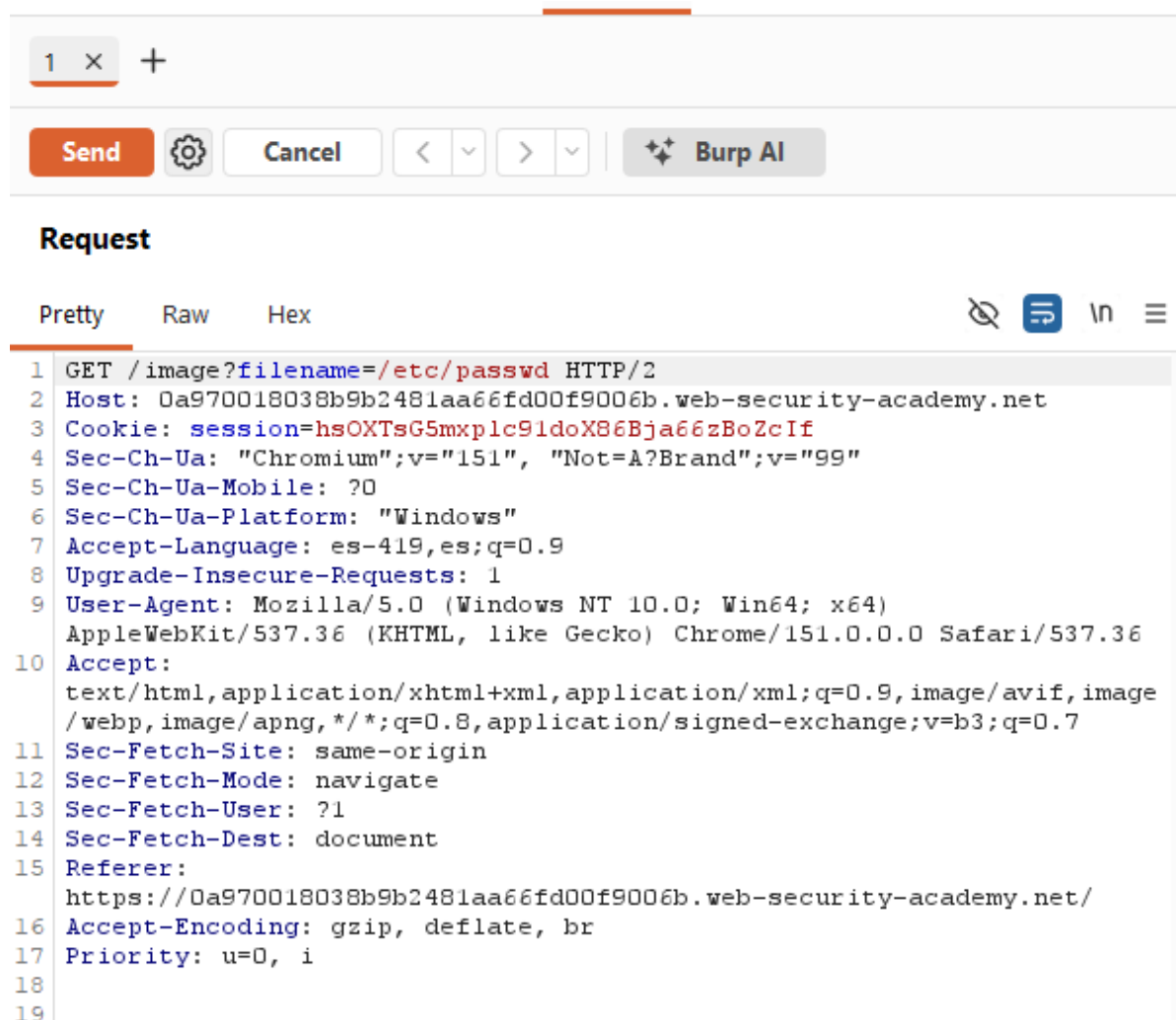
Items added to site map

[View site map](#)

Host	Method	URL	Status co...	MIME type
0a970018038b9b248...	GET	/	200	HTML
0a970018038b9b248...	GET	/resources/labheader/css/academ...	200	CSS
0a970018038b9b248...	GET	/resources/css/labsEcommerce.css	200	CSS
0a970018038b9b248...	GET	/resources/labheader/js/labHead...	200	script
0a970018038b9b248...	GET	/resources/images/shop.svg	200	XML
0a970018038b9b248...	GET	/image?filename=5.jpg	200	
0a970018038b9b248...	GET	/resources/images/rating5.png	200	PNG
0a970018038b9b248...	GET	/product?productId=1	200	
0a970018038b9b248...	GET	/image?filename=75.jpg	200	
0a970018038b9b248...	GET	/resources/images/rating2.png	200	PNG
0a970018038b9b248...	GET	/product?productId=2	200	
0a970018038b9b248...	GET	/image?filename=43.jpg	200	
0a970018038b9b248...	GET	/resources/images/rating3.png	200	PNG
0a970018038b9b248...	GET	/product?productId=3	200	
0a970018038b9b248...	GET	/image?filename=48.jpg	200	
0a970018038b9b248...	GET	/resources/images/rating4.png	200	PNG
0a970018038b9b248...	GET	/product?productId=4	200	
0a970018038b9b248...	GET	/image?filename=42.jpg	200	
0a970018038b9b248...	GET	/product?productId=5	200	
0a970018038b9b248...	GET	/image?filename=30.jpg	200	
0a970018038b9b248...	GET	/product?productId=6	200	
0a970018038b9b248...	GET	/image?filename=16.jpg	200	
0a970018038b9b248...	GET	/resources/images/rating1.png	200	PNG

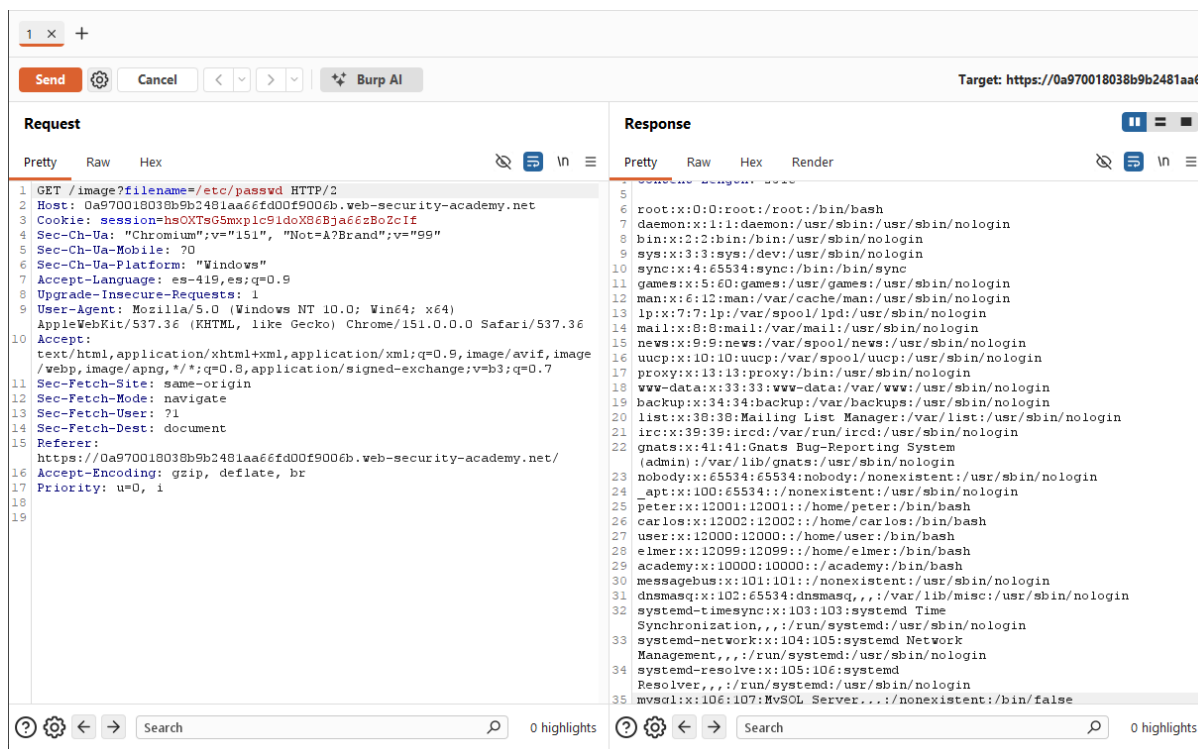


Durante la fase de reconocimiento en Burp Suite, se identificó un patrón inseguro en las peticiones GET hacia /image. La aplicación emplea el parámetro filename para la carga de recursos. Este parámetro se convierte en un vector ideal para inyectar secuencias de salto de directorio. Para un análisis más profundo usamos la función Proxy de Burp Suite.



Haciendo un análisis rápido podemos ver que el método GET directamente llama a las imágenes, así que intentaremos atacar a través de ellas. Para esto, enviamos la petición al 'Repeater' y preparamos el payload eliminando el nombre de la imagen y colocando la ruta absoluta del archivo que deseamos ver: **/etc/passwd**. A diferencia

del caso anterior, aquí no se utilizan secuencias de salto de directorio (../), ya que la aplicación las bloquea; en su lugar, se aprovecha que el filtro no valida si la ruta suministrada ya es absoluta.



Damos clic en "Send" y podemos observar que tuvimos éxito y tenemos acceso al archivo `passwd`.

Explicación del Payload

El parámetro `filename` indica al servidor qué archivo leer del disco duro. En este laboratorio, la aplicación filtra las secuencias de salto de directorio (../), por lo que intentar ascender manualmente en la jerarquía de carpetas resulta bloqueado. Sin embargo, el filtro únicamente valida la presencia de esos patrones relativos y no verifica si la ruta suministrada ya es una ruta absoluta. Al colocar `/etc/passwd` directamente, sin ninguna secuencia de traversal, la aplicación interpreta esta cadena como la ruta absoluta del archivo dentro del sistema, saltándose por completo la carpeta raíz web asignada y accediendo directamente a `/etc/passwd`, que en este caso es la lista de usuarios del sistema.

Mitigación Recomendada

- **Evitar entradas directas:** Lo más efectivo es evitar, lo más que se pueda, pasar la entrada directa al sistema de archivos. En su lugar, se podrían usar identificadores en una base de datos para localizar un archivo.
- **Validación estricta:** Si es estrictamente necesario que el usuario coloque alguna entrada para nombrar algún archivo, se debe implementar una validación robusta (ej. que contenga solamente caracteres alfanuméricos). Así se rechazan en automático instrucciones de escape como `../` o bytes nulos `%00`.
- **Rutas Absolutas:** Tras recibir la entrada, la aplicación debe anexarla al directorio base estricto y utilizar funciones de canonicalización provistas por el lenguaje de programación (ej. `realpath()` o `os.path.abspath()`). Finalmente, el sistema debe verificar de forma rigurosa que la ruta absoluta resultante comience exactamente con el directorio base autorizado antes de proceder con la lectura del archivo.

Referencias

OWASP. (s.f.). *Path Traversal*. OWASP Community. Recuperado el 21 de septiembre de 2026, de https://community.owasp.org/attacks/Path_Traversal